Tokens (see chapter 6) can be useful for implementing persistent cookies without storing long-lived state on the server.

You should always set cookies with the most restrictive attributes that you can get away with. The Secure and HttpOnly attributes should be set on any cookie used for security purposes. Avoid setting a Domain attribute unless you absolutely need the same cookie to be sent to multiple sub-domains, as if just one sub-domain is compromised then session fixation attacks become easier to pull off as described in the previous section. Sub-domains are often a weak point in web security due to the prevalence of *sub-domain hijacking* vulnerabilities.

> **DEFINITION** ***Sub-domain hijacking*** (or ***sub-domain takeover***) occurs when an attacker is able to claim an abandoned web host that still has valid DNS records configured. This typically occurs when a temporary site is created on a shared service like Github Pages and configured as a sub-domain of the main website. When the site is no longer required, it is deleted but the DNS records are often forgotten. An attacker can discover these DNS records and re-register the site on the shared web host, under the attacker's control. They can then serve their content from the compromised sub-domain.

Spark produces Secure cookies by default, but you can configure it to also mark them as HttpOnly by adding the following line to the top of the `main()` method (before any